What ONE Already Does

Every capability on these pages **exists in the product today**. Nothing planned, deferred or aspirational appears here — that belongs in the companion briefing. Each promise is printed beside the mechanism that enforces it, and the closing appendix names the file you can open to check.

182	33	77	11	9	3
LIVE API ROUTES	DATABASE MIGRATIONS	TEST SUITES	ROLE PORTALS	QUESTION FORMATS	CLIENTS: WEB, PHONE, API

01 Promises the system cannot break

Most products state these as policy in a document. In ONE they are structural: the database or the type system refuses the operation, so a future change made in a hurry cannot quietly undo them.

An employer can never see a readiness band

And no readiness record can be marked as anything other than advisory. This is the promise the whole product rests on, so it is not left to a permission check.

> ENFORCED BY
>
> Two CHECK constraints on `readiness_snapshots`: `CHECK (advisory)` and `CHECK (NOT employer_visible)`. A row that breaks either promise cannot be written at all — not by a bug, not by a migration, not by hand.

A verified academic record can never be un-verified

Once an institution confirms a result, that confirmation is permanent, and the identity of the person who confirmed it cannot be altered afterwards.

> ENFORCED BY
>
> A database trigger, `academic_verification_is_final()`, on both the qualification and term tables. It raises *"a verified academic record cannot be unverified"* and *"the verifier of a verified academic record cannot be changed"*.

One college cannot reach another college's data

A question written at one institution cannot appear in another institution's paper. Intellectual property is locked to its owner permanently, with no unlock switch for anyone — including us.

> ENFORCED BY
>
> Composite foreign keys carrying the institution id through every reference — `(subject_id, institution_id)`, `(unit_node_id, institution_id)`. The cross-tenant link is not forbidden; it is *inexpressible*. A developer who forgets the check gets an error, not a leak.

Only the issuing institution can verify a record

A second college cannot rubber-stamp a qualification it did not award, however convenient that would be for a transfer student. And a qualification naming an institution that is not on ONE stays honestly self-reported.

> ENFORCED BY
>
> The decision query is scoped to `q.institution_id = :institutionId`, plus a CHECK that a qualification with no linked institution can only hold `SELF_REPORTED`.

Answer keys never reach the student's device

They cannot be extracted from the browser, because they are never sent to it. The paper is frozen at the moment the attempt starts, and a submitted attempt cannot be rewritten by anyone.

> ENFORCED BY
>
> Learner responses omit answer keys and scoring explanations by construction. Question selection uses deterministic cryptographic hash ordering; the server freezes exact question revisions; submission is transactionally idempotent.

An unscanned file is never stored

If the malware scanner is unavailable, the upload is refused. The system does not take the easy path of storing it now and checking later.

> ENFORCED BY
>
> Every scanner failure mode resolves to `SCAN_FAILED` rather than throwing or defaulting to clean. The student is told the file was not stored and to try again shortly.

Stored documents are encrypted individually

Resumes, certificates and transcripts — the densest personal data the platform holds — are each encrypted under their own randomised initialisation vector.

> ENFORCED BY
>
> AES-256-GCM per file, with a header carrying a magic marker, a version and an 8-byte key fingerprint — so "restored with the wrong key" surfaces as a named error rather than silent corruption.

A small cohort cannot be re-identified in a report

"One student in this section is struggling" identifies that student. Institution reporting refuses to produce it.

> ENFORCED BY
>
> Aggregate institution reports suppress any cohort below five members and return a suppression marker instead of figures. Downloadable institution artifacts expire after 30 days.

A published profile link leaks nothing if the database does

A student can publish a page anyone with the link can open, and switch it off for everybody at once. An unknown, expired and revoked link are indistinguishable to whoever holds one.

> ENFORCED BY
>
> Only a `sha256` digest of the token is stored — the raw link is shown once, to its owner, and cannot be recovered. The page resolver does not join `readiness_snapshots`, `applications` or the document files at all, so there is nothing to filter out.

A screening result never becomes readiness evidence

An employer can build a question bank and send a test to applicants. What they measure stays theirs: it does not feed the band, and they never see the band either.

> ENFORCED BY
>
> The employer assessment tables do not reference `evidence_records`, `mastery_projections` or `readiness_snapshots`. A test counts rows in all three before and after a submission and asserts they are unchanged.

An employer can tell a candidate why, without exposing their own notes

What a recruiter recorded for their team stays private. Releasing feedback is a second, deliberate act from a shared vocabulary, and it can be corrected but never retracted.

> ENFORCED BY
>
> Separate tables from `applications.rejection_reason_code`, which is untouched. A correction supersedes rather than overwrites, and a partial unique index allows exactly one live release.

Nothing is ever deleted to hide a correction

Corrections append; they do not erase. A replanned roadmap supersedes the old one rather than overwriting it, and application stage changes are kept as history.

> ENFORCED BY
>
> Superseding rows with a `superseded_at` marker, an immutable `application_state_history` table, and versioned questions so a student's past paper still shows what they actually sat.

---

02 What each role can do today

Working journeys against real data, with the server re-checking authorization on every request. Nothing in this section is a mock-up.

Student

WEB AND PHONE

- Edit their own profile, target career and visibility settings
- Declare qualifications and semester results, and **submit them to their institution to verify**
- Upload documents — scanned, encrypted, versioned — and manage the metadata
- Work through lessons and modules, with completion stored as immutable evidence
- Sit assigned assessments and see results, with a per-student frozen paper
- See their readiness band, the factors behind it, and a roadmap of next actions
- Choose career targets and see requirement-by-requirement gaps
- Browse and save opportunities, apply, withdraw, and respond to offers
- Log applications made **outside** ONE, and grant or revoke institution visibility on each
- Complete tasks assigned by staff
- See **why an employer rejected them**, where that employer chose to say
- Sit screening tests employers send them, on a laptop or a phone
- See one calendar of interviews, exam windows, tasks and deadlines, and export it
- **Publish a profile behind a revocable link**, choosing what it shows, and switch it off for everyone at once
- Grant and withdraw consent, **export everything**, and request deletion

Institution

ADMIN, PLACEMENT, FACULTY, DEPARTMENT

- Build academic structure — departments, programmes, batches, sections
- Manage the student roster, and transfer, graduate or end a relationship
- **Import a roster from CSV** with a full preview before anything is committed
- Invite staff and inspect the invitation and membership inventory
- Work an **academic verification queue** and decide each submitted result
- Build a governed question bank across nine formats, with review states and duplicate detection
- Assemble exams by blueprint from approved questions only, publish, assign and read results
- Assign tasks and interventions to students and track them to completion
- Read readiness reporting for their own cohorts, aggregate and suppressed below five
- Work a queue of **verification requests from former students**, told whether each person is current, former, or not on their roster
- See student applications they have been granted visibility of

Employer

RECRUITER, HIRING MANAGER, INTERVIEWER

- Create opportunities, version them, and **target specific audiences** rather than the open internet
- Publish, and receive applications from consenting candidates
- Move candidates through ten defined stages, with every transition kept as history
- Schedule interviews — onsite, video or phone — with validated joining links
- Assign a panel by role: interviewer, hiring manager, observer, coordinator
- **An interviewer sees only their own assigned interview**, not the wider pipeline
- Record structured scorecards and interview outcomes
- Draft, issue and withdraw offers — compensation never visible to the institution
- **Build a question bank and send a screening test** to applicants, with a second person approving each question
- Release structured feedback to a rejected candidate, choosing what is said
- Read hiring analytics on their own funnel

Operations

PLATFORM TEAM

- Create, edit and **verify organisations**, and invite their first administrator
- Inspect identities, memberships and invitation delivery state
- Grant and revoke an institution's capabilities
- **Switch any feature off** globally, for one organisation, or for one person — every flip stamped with a reason code
- Set per-feature caps by invocation, tokens or cost, per day or per month
- Open, progress and act on trust-and-safety cases
- Read the platform audit log
- Place and release legal holds so an automatic deletion cannot erase evidence under investigation
- **Write, review and publish learner content**, with approval and publication requiring two different people
- See failed outbound events and replay or supersede them

03 What runs on the phone

The Android app is a real client against the same API and the same authorization, not a viewer. It carries the AI8HT wordmark and the pilot design language rather than a default Material shell.

Student journey

BUILT

- Home, assessments, learning, jobs and profile
- Readiness shown as a band on the phone too, with real mastery
- Consent gate before first use, with export and erasure in settings
- Notifications inbox and device registration
- Browser-based sign-in so two-factor will work when it is switched on
- An expired session signs out cleanly rather than looping on retry

Staff and employer

BUILT

- Workspace chooser for a person holding more than one role
- Institution dashboard with exams and results
- Employer dashboard with applicants, interviews, scorecards, offers and analytics
- Operations overview of organisations and invitations
- Help and FAQ per persona
- **Exams are deliberately laptop-only** — the app says so plainly and keeps the timer honest

04 How it is operated and recovered

Backups survive a total compromise of the server

An attacker who owns the machine completely still cannot read or forge the backups — because the ability to decrypt them was never on that machine.

> ENFORCED BY
>
> Backups are encrypted to a public key. Only the public half is ever copied to the server; the private key lives in the operator vault. A lost offsite copy is ciphertext, not a breach.

Silence is treated as failure

If the host dies, nobody has to notice. The alarm fires on its own.

> ENFORCED BY
>
> Two dead-man's-switch checks — a daily backup ping and a ten-minute monitor ping. An alert fires both when a script reports failure and when pings simply stop arriving.

Recovery is written down, not improvised

The procedures exist before they are needed, which is the only time they can be written calmly.

> ENFORCED BY
>
> Six operational runbooks: deploy, rollback, restore, backups and monitoring, breach response, and demo preparation.

05 Check any of it yourself

A briefing that asks to be believed is worth less than one that tells you where to look. Every claim above can be opened and read.

Readiness is advisory and never employer-visible

`packages/persistence/drizzle/0004_v4_career_readiness.sql — readiness_snapshots`

Verification is permanent and the verifier is fixed

`packages/persistence/drizzle/0070_academic_records.sql — academic_verification_is_final()`

Only the issuing institution verifies; queue ignores enrolment

`packages/persistence/src/academic-records.ts — decideTermVerification, listVerificationQueue`

Cross-tenant question reuse is inexpressible

`packages/persistence/drizzle/0012_assessment_engine.sql — composite foreign keys`

Bands, factors, roadmap actions and cohort suppression

`packages/career-readiness/src/index.ts · packages/persistence/src/career-readiness.ts`

Per-file encryption format and key fingerprinting

`apps/api/src/storage/encrypted-storage.ts`

Scanner failure refuses the upload

`apps/api/src/storage/clamav.ts`

Feature kill switch, scoped overrides and reason codes

`packages/persistence/drizzle/0029_feature_flags.sql · apps/api/src/http/platform-controls.controller.ts`

Hiring stages, interview modes, panel roles, offers	`packages/persistence/drizzle/0007_opportunity_hiring_domain.sql` · `apps/api/src/http/employer-hiring.controller.ts`
Every request’s authorization boundary	`apps/api/src/http/api-security.ts`
Decisions taken, and what was rejected	`docs/architecture/ADR-*.md` — readiness bands (020), offer visibility (024), the outbox (028)
Backups, monitoring and recovery procedures	`docs/ops/runbook-*.md` · `deploy/scripts/backup-and-verify.sh`

How these numbers were produced. The counts in the header are measured from the repository, not estimated: routes counted from the HTTP controllers, migrations and test suites from the file tree. The capability statements were each checked against the code that implements them while this document was written, and the whole test suite was run against a real database: **every suite passes** — the web application, the API including its database-backed integration tests, the persistence package, and ten domain packages. The flaky sign-in tests noted in the previous edition were diagnosed and fixed; they were slow, not broken. One limit remains, stated rather than buried: an **independent penetration test has still not been done**, so every security claim above is our own assessment of our own work. **Where something is only partly built, it is absent from these pages rather than softened** — the companion briefing carries it instead.

© AI8HT. ALL RIGHTS RESERVED.